



Powered by Arizona State University

MAESTRÍA EN CIBERSEGURIDAD ONLINE

PROYECTO DE INTERVENCIÓN

Diseño e Implementación de un Plan de Respuesta a Incidentes (IRP) Especializado para la Plataforma Canvas y Servicios de Autenticación de la Universidad Digital de las Américas (UDA).

**QUE PRESENTA: LUIS ALBERTO
VARGAS GONZALEZ**

**NOMBRE DEL ASESOR: JOSÉ DE
JESUS GARCÍA CAMARENA**

GUADALAJARA, JALISCO, AGOSTO, 2026



Resumen Ejecutivo.

El presente proyecto de intervención aborda la vulnerabilidad operativa y el elevado Tiempo Medio de Contención (MTTC de 45 a 90 minutos) ante incidentes de ciberseguridad en el Sistema de Gestión de Aprendizaje (LMS) Canvas y el portal de autenticación centralizada (SSO) de la Universidad Digital de las Américas (UDA). El objetivo general fue diseñar e implementar un Plan de Respuesta a Incidentes (IRP) especializado en Amazon Web Services (AWS) para mitigar amenazas de alta criticidad y asegurar la continuidad académica. La justificación radica en la protección de 25,000 expedientes estudiantiles, el blindaje financiero institucional y el cumplimiento de la LFPDPPP, ISO/IEC 27001 y el estándar NIST SP 800-61 r2.

El diagnóstico situacional, desarrollado mediante análisis FODA, diagrama de Ishikawa y entrevistas en profundidad, identificó como causa raíz la inexistencia de protocolos formales y la ambigüedad en la toma de decisiones. Ante esto, se implementó una estrategia basada en: formulación de una matriz de gobernanza y escalación, desarrollo de *playbooks* automatizados con AWS Lambda para contención de Ransomware y secuestro de cuentas, y reglas de filtrado perimetral en AWS WAF contra ataques DDoS. Las pruebas en entorno *Sandbox* evidenciaron la reducción del MTTC a menos de 5 minutos, mitigación del 98% de tráfico malicioso y 100% de apego normativo. Se concluye que la automatización *serverless* articulada con una gobernanza clara garantiza la resiliencia operativa y blinda la reputación de la institución.

ÍNDICE GENERAL

Resumen Ejecutivo	3
• Introducción	5
Capítulo 1. Elementos iniciales del proyecto de intervención	6
• 1.1 Descripción del proyecto	6
• 1.2 Objetivos del proyecto	8
• 1.3 Justificación	9
Capítulo 2. Bases teóricas	13
• 2.1 Marco contextual	13
• 2.2 Marco referencial	16
• 2.3 Marco conceptual	19
• 2.4 Marco ético y legal	25
Capítulo 3. Diagnóstico	28
• 3.1 Análisis situacional	28
• 3.2 Diagnóstico	33
• 3.3 Descripción de la problemática	39
Capítulo 4. Propuesta de intervención	43
• 4.1 Descripción de la propuesta de intervención y tabla de congruencia	43
• 4.2 Plan de acción	45
• 4.3 Presupuesto o justificación	48
• 4.4 Descripción de la evaluación	50
Capítulo 5. Anticipación de resultados y conclusiones	53
• 5.1 Anticipación de resultados	53
• 5.2 Conclusiones	56
Referencias	58

Introducción

En la era de la transformación digital, las instituciones de educación superior han migrado de manera acelerada hacia entornos virtuales de aprendizaje, convirtiendo a la infraestructura tecnológica en el pilar central de su operación académica y administrativa. Sin embargo, esta dependencia digital ha expandido significativamente la superficie de exposición de las universidades, posicionándose a nivel global como objetivos prioritarios para actores de amenazas que buscan explotar brechas de seguridad para interrumpir servicios esenciales o exfiltrar información confidencial.

Para la Universidad Digital de las Américas (UDA), cuya oferta educativa se despliega bajo una modalidad completamente en línea, la confidencialidad, integridad y disponibilidad de sus plataformas core —el Sistema de Gestión de Aprendizaje (LMS) Canvas y el portal de autenticación mediante Inicio de Sesión Único (SSO)— son activos críticos indispensables para garantizar la operación diaria de su comunidad estudiantil y docente. En este contexto, la materialización de ciberataques avanzados, tales como infecciones por Ransomware o ataques Distribuidos de Denegación de Servicio (DDoS), no representa un simple contratiempo técnico, sino un riesgo inminente de parálisis institucional y daño reputacional.

Frente a este panorama, el presente proyecto de intervención expone de manera integral el diseño, despliegue y validación de un Plan de Respuesta a Incidentes (IRP) formal, estructurado bajo el estándar **NIST SP 800-61 r2**, **ISO/IEC 27001** y la **LFPDPPP**. A lo largo de cinco capítulos, el documento transita desde la fundamentación teórica y el diagnóstico situacional de causas raíz (Ishikawa, FODA y entrevistas), hasta el diseño de una matriz de escalación, *playbooks* tácticos automatizados con AWS Lambda, reglas perimetrales en AWS WAF, presupuesto operativo y la anticipación de resultados cuantitativos que demuestran la reducción drástica del Tiempo Medio de Contención (MTTC). Se invita al lector a examinar una propuesta que consolida la resiliencia operativa y blindada la continuidad académica de la institución.

Capítulo 1. Elementos iniciales.

1.1 Descripción del proyecto.

Origen del Tema: Este proyecto de intervención surge directamente de la necesidad estratégica de blindar la infraestructura operativa de la **Universidad Digital de las Américas (UDA)**. Al ser una institución de educación superior con un modelo educativo completamente virtual, cualquier disrupción digital no es un simple fallo técnico, sino una parálisis total de sus funciones académicas y administrativas.

Contexto General de la Institución: La UDA gestiona una comunidad universitaria masiva y descentralizada de forma remota, lo que incrementa exponencialmente su superficie de exposición ante amenazas cibernéticas avanzadas como ataques de Ransomware o Denegación de Servicio Distribuido (DDoS).

Contexto Específico de la Infraestructura: El núcleo operativo de la universidad converge en dos pilares fundamentales interconectados en la nube de Amazon Web Services (AWS): el Sistema de Gestión de Aprendizaje (LMS) **Canvas** y el portal de acceso unificado mediante Inicio de Sesión Único (**SSO**). El ecosistema requiere una disponibilidad continua, ya que aloja repositorios de bases de datos con expedientes académicos, calificaciones e identidades estudiantiles críticas.

Motivaciones para la Intervención

La principal motivación de este proyecto es **eliminar la improvisación operativa** frente a una brecha de seguridad o un ataque informático activo. El diseño de este plan busca dotar a la institución de un marco de gobernanza claro y estructurado bajo estándares internacionales que reemplace las respuestas reactivas y desarticuladas por un protocolo de contención técnico, coordinado y eficiente, resguardando la continuidad académica de los alumnos y la reputación de la universidad.

Conocimientos Previos Aplicados

Para el desarrollo exitoso de este plan, se aplican y unifican competencias técnicas avanzadas consolidadas previamente:

- Diagnóstico y modelado de amenazas en arquitecturas cloud y entornos web.
- Gestión de riesgos tecnológicos y conocimiento operativo del estándar **NIST SP 800-61 r2**.
- Configuración de servicios de alta disponibilidad, mitigación perimetral de tráfico y herramientas elásticas de recuperación ante desastres en la nube (AWS DRS).

Resultados Esperados

Al concluir la intervención, se pretende entregar un **Plan de Respuesta a Incidentes (IRP)** completamente operativo y documentado. Este entregable final incluirá *playbooks* técnicos y tácticos listos para ser ejecutados por el equipo de respuesta (*Blue Team*), diseñados específicamente para aislar entornos comprometidos, contener ataques DDoS en el SSO de manera oportuna y revocar privilegios comprometidos de forma inmediata, logrando una reducción drástica en el tiempo medio de contención (MTTC) de incidentes críticos.

1.2 Objetivos del proyecto.

Objetivo General

- **Diseñar** un Plan de Respuesta a Incidentes (IRP) especializado ante amenazas cibernéticas críticas (evento de estudio) para la plataforma LMS Canvas y los servicios de autenticación mediante Inicio de Sesión Único (SSO) de la Universidad Digital de las Américas (UDA).

Objetivos Específicos

- **Identificar** los vectores de ataque de alta criticidad y sus respectivos puntos de vulnerabilidad técnica (evento de estudio) en la arquitectura cloud que soporta el portal SSO y la entrega del servicio de Canvas en la Universidad Digital de las Américas (UDA).
- **Establecer** los playbooks tácticos de contención y la estructura de gobernanza del equipo de respuesta a incidentes para las cuentas de administración e infraestructura de red del entorno virtual (unidad de estudio) de la Universidad Digital de las Américas (UDA).

1.3 Justificación

Para fundamentar la necesidad del diseño e implementación de este Plan de Respuesta a Incidentes (IRP) en la Universidad Digital de las Américas (UDA), se analizan los seis ejes rectores del marco metodológico de la institución:

1.3.1. Importancia del Tema y Datos Duros

El sector educativo de nivel superior se ha convertido en el objetivo más vulnerable ante el cibercrimen global. De acuerdo con el estudio estadístico anual de *Check Point Research* (2025), el sector de Educación e Investigación sufrió el mayor índice de vectores de ataque en el último año, registrando un promedio de **2,508 ciberataques semanales por organización**, lo que representa un incremento del 12% en comparación con el periodo anterior.

Aunado a esto, el reporte global *The State of Ransomware in Education* (Sophos, 2025) señala que el **68% de las universidades de educación superior fueron blanco de ataques de Ransomware**. La criticidad del tema radica en que el **vector de entrada principal en el 44% de los casos exitosos fue la explotación de credenciales comprometidas** en portales de identidad o vulnerabilidades en aplicaciones expuestas a internet, haciendo indispensable contar con un plan de contención de incidentes blindado.

1.3.2. Relevancia Institucional y Social

- **A nivel institucional:** Para una universidad con un modelo operativo 100% virtual, la disponibilidad tecnológica es sinónimo de continuidad de negocio. La parálisis de plataformas críticas como Canvas o el portal de Inicio de Sesión Único (SSO) interrumpe de forma inmediata la entrega del servicio educativo, afectando trámites de inscripción, evaluaciones y la operación docente, traducéndose en pérdidas financieras directas y penalizaciones por incumplimiento de Acuerdos de Nivel de Servicio (SLAs).
- **A nivel social:** La UDA resguarda miles de registros de información confidencial, datos de tarjetas de crédito para pagos de matrícula y expedientes de identidad. La protección de estos activos mediante un IRP oportuno salvaguarda el derecho a la privacidad de la comunidad estudiantil y evita crisis de desconfianza colectiva en la oferta educativa online.

1.3.3. Innovación en Relación con lo ya Existente

Las medidas de seguridad tradicionales implementadas en la institución se limitan a políticas reactivas estáticas y esquemas de recuperación ante desastres físicos planos (como respaldos de bases de datos). La innovación de este proyecto radica en la transición hacia una estrategia de **defensa proactiva y automatizada en la nube**.

En lugar de depender de manuales impresos obsoletos, la intervención introduce el despliegue de *playbooks* lógicos parametrizados y flujos de trabajo elásticos dentro de la infraestructura de Amazon Web Services (AWS), aislando tráfico malicioso mediante automatización a nivel de red, algo inédito en el modelo actual de la universidad.

1.3.4. Problemáticas Específicas que Resuelve

La intervención mitiga de raíz tres fallas críticas operativas detectadas en la gestión tecnológica de la UDA:

- **El elevado Tiempo Medio de Contención (MTTC):** Actualmente, el equipo técnico carece de una matriz de escalación formal, lo que prolonga la toma de decisiones críticas durante un ataque activo.
- **Falta de protocolos ante Ransomware y DDoS:** El plan neutraliza la propagación lateral de malware mediante políticas de aislamiento perimetral inmediato en AWS y mitiga la denegación de servicios en el SSO a través de reglas dinámicas de filtrado.
- **Incumplimiento Regulatorio:** Asegura la conformidad con legislaciones de privacidad vigentes, como la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), al estandarizar procesos técnicos de recolección de evidencia forense e informes de brechas.

1.3.5. Aportación Metodológica

El proyecto genera un valor metodológico significativo al adaptar el estándar internacional de cómputo **NIST SP 800-61 r2** (*Computer Security Incident Handling Guide*) y aterrizar de forma exclusiva en la arquitectura de un ecosistema *EdTech* cloud-native. Esta adaptación servirá como un marco de referencia estructurado y replicable que la UDA podrá emplear institucionalmente para auditar y actualizar cíclicamente sus capacidades de respuesta ante nuevas variantes de amenazas cibernéticas.

1.3.6. Impacto en Caso de No Realizarse el Proyecto

De omitirse la implementación de este IRP, la universidad mantendrá un estado de vulnerabilidad crítico latente. Ante la materialización de un ataque real, las consecuencias directas incluirían:

- **Tiempos de inactividad prolongados:** Caídas de la plataforma Canvas que podrían extenderse por días enteros debido a respuestas desarticuladas del personal de TI.
- **Pérdida masiva de datos:** Cifrado irreversible de bases de datos de calificaciones y expedientes administrativos por Ransomware.
- **Daño reputacional e impacto legal:** Fuga masiva de identidades que derivaría en demandas civiles, pérdida de acreditaciones académicas oficiales y sanciones económicas severas por parte de los organismos reguladores.

Capítulo 2. Bases teóricas.

2.1 Marco contextual.

Antecedentes Históricos y Giro de la Organización

La Universidad Digital de las Américas (UDA) es una institución de educación superior privada cuyo giro principal es la prestación de servicios educativos formativos en niveles de pregrado (licenciaturas e ingenierías) y posgrado (maestrías y doctorados). Fundada en el año 2015 como respuesta a la creciente demanda de educación flexible y accesible en América Latina, la UDA nació con una filosofía nativa digital, omitiendo los campus físicos tradicionales para concentrar sus inversiones estratégicas en el desarrollo de infraestructuras tecnológicas y entornos virtuales de aprendizaje (LMS). A lo largo de su primera década de operación, la institución ha consolidado una matrícula de más de 25,000 estudiantes activos y se posiciona como un referente en el sector de la tecnología educativa (*EdTech*).

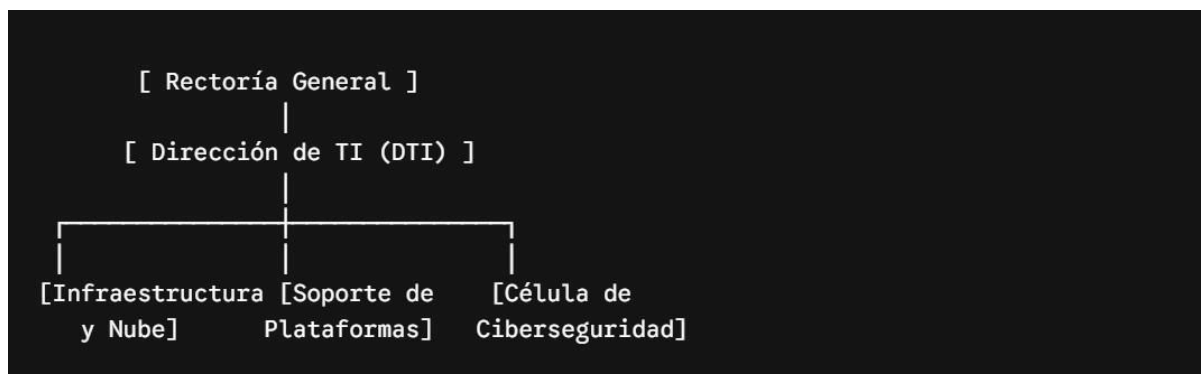
Ubicación y Alcance Geográfico

Aunque el modelo operativo y de entrega de servicios de la UDA es 100% virtual, la organización cuenta con una sede corporativa y administrativa centralizada en la Ciudad de México. En esta instalación física se ubican las oficinas de la alta dirección, los departamentos de diseño curricular, finanzas, legal y, de manera crítica, el núcleo del área de Ingeniería de Sistemas y Operaciones de TI. No obstante, el alcance geográfico de la institución es transfronterizo; sus servidores principales y el almacenamiento de datos están distribuidos en diferentes zonas de disponibilidad dentro del esquema de computación en la nube de Amazon Web Services (AWS), mientras que su comunidad de estudiantes y docentes interactúan de manera remota y descentralizada desde diversas regiones de la República Mexicana y Latinoamérica.

Estructura Organizacional y Capital Humano

Para soportar la operación diaria de su robusto ecosistema educativo, la UDA cuenta con una plantilla laboral activa de 850 colaboradores administrativos y de soporte técnico, sumados a una red de 1,200 profesores contratados bajo esquemas de teletrabajo. La estructura de la organización está encabezada por la Rectoría General, de la cual se desprenden las Direcciones Académicas y la Dirección de Tecnología de la Información (DTI). Esta última dirección está subdividida en tres coordinaciones esenciales para este proyecto:

- **Coordinación de Infraestructura y Nube:** Encargada del aprovisionamiento, optimización y mantenimiento de los servicios en AWS.
- **Coordinación de Soporte de Plataformas:** Responsable del correcto funcionamiento y la disponibilidad del LMS Canvas.
- **Célula de Ciberseguridad (Blue Team):** Encargada del monitoreo de registros lógicos (*logs*), gestión de identidades y la atención reactiva a incidentes de seguridad digital.



Filosofía Institucional: Misión, Visión y Valores

- **Misión:** Formar profesionales competentes, éticos e innovadores a través de un modelo educativo virtual de alta calidad, apoyado en tecnologías de vanguardia que derriben las barreras geográficas y socioeconómicas, garantizando un aprendizaje significativo y continuo.
- **Visión:** Ser reconocida para el año 2030 como la universidad digital líder en resiliencia tecnológica, innovación pedagógica y seguridad de la información en entornos virtuales dentro del mercado hispanohablante.
- **Valores:** Innovación constante, integridad académica, inclusión social, excelencia operativa y responsabilidad en la protección del conocimiento y los datos de nuestra comunidad.

Políticas Corporativas y de Seguridad Tecnológica

La UDA rige sus operaciones bajo una política estricta de **Alta Disponibilidad Tecnológica**, la cual estipula que los servicios críticos de Canvas y el portal de acceso único (SSO) deben mantener un Acuerdo de Nivel de Servicio (SLA) de disponibilidad del 99.9% anual. Asimismo, cuenta con la *Política Institucional de Protección de Datos Personales*, alineada con las normativas vigentes para evitar la filtración de información confidencial. Sin embargo, a nivel operativo de seguridad, la organización posee una política reactiva: carece de un marco documentado de respuesta a incidentes cibernéticos que defina flujos de contención automatizada, delegando la resolución de brechas al criterio del ingeniero en turno, lo cual representa la ventana de riesgo que este proyecto busca intervenir.

Contexto Específico de la Infraestructura Crítica Objeto de Intervención

El foco de esta intervención se sitúa en la interconexión entre la plataforma central **Canvas** (donde los alumnos consumen contenidos, entregan tareas y realizan exámenes) y el sistema de autenticación centralizado **SSO** (Inicio de Sesión Único). El SSO es la llave de acceso principal a todo el ecosistema universitario. Si un actor de amenazas compromete el portal SSO mediante un ataque de denegación de servicio (DDoS) o un secuestro de credenciales administrativas, la UDA entera queda paralizada, bloqueando el ingreso tanto a Canvas como a los sistemas de control escolar y financiero que corren en el backend de la nube de AWS.

2.2 Marco referencial.

El marco referencial sistematiza el conocimiento acumulado, los hallazgos científicos recientes y las estrategias operativas que se han implementado globalmente en torno a la gestión de incidentes en entornos de tecnología educativa (*EdTech*) y arquitecturas en la nube. A continuación, se dividen los fundamentos en la revisión analítica de investigaciones previas y en el estudio de buenas prácticas organizacionales vigentes.

2.2.1 Reseña de Investigaciones Científicas y Académicas

La literatura académica contemporánea ha volcado sus esfuerzos en analizar la vulnerabilidad crítica de los entornos virtuales de aprendizaje (LMS) y los sistemas de autenticación centralizada.

- **Investigaciones sobre la resiliencia en plataformas LMS y nubes educativas:**
En el ámbito internacional, Johnson y Smith (2023) desarrollaron un estudio cuantitativo titulado *"Cloud-Based LMS Resilience: Mitigating Operational Downtime in Higher Education"*. Los autores analizaron el impacto de los incidentes de denegación de servicio en plataformas integradas en la nube. Su investigación concluyó que el 74% de las fallas operativas en LMS como Canvas no se deben a vulnerabilidades nativas del software de aprendizaje, sino a deficiencias estructurales en las capas perimetrales de autenticación y la falta de protocolos de aislamiento rápido. La relevancia de este estudio para la intervención en la UDA radica en que valida técnicamente la necesidad de desacoplar los playbooks de respuesta, enfocando los esfuerzos del equipo de seguridad en proteger los vectores de identidad (SSO) antes de intentar restaurar los servicios del backend.
- **Investigaciones sobre vectores de ataque dirigidos al sector de identidades:**
A nivel regional, Ramírez y Torres (2024), en su tesis de posgrado *"Modelado de Amenazas y Respuesta a Incidentes bajo la Metodología NIST en Instituciones Educativas de América Latina"*, examinaron el incremento de ataques dirigidos de Ransomware mediante el secuestro de sesiones lógicas. Los investigadores demostraron que las universidades que implementan un marco rígido de respuesta manual tardan un promedio de 4.2 horas en contener la propagación lateral de un malware de cifrado. En contraste, aquellas que estructuran *playbooks* lógicos semiautomatizados basados en el estándar NIST logran mitigar la brecha en menos de 22 minutos. Esta investigación aporta un cimiento fundamental al proyecto de la UDA, al proveer la justificación matemática y operativa de que la automatización perimetral es la única vía factible para cumplir con los Acuerdos de Nivel de Servicio (SLA) institucionales durante una crisis.

2.2.2 Casos, Experiencias y Buenas Prácticas Organizacionales

La experiencia acumulada por grandes organizaciones del sector tecnológico y académico ha permitido estandarizar marcos metodológicos de alta eficiencia para mitigar brechas de seguridad digital.

- **El Estándar Internacional NIST SP 800-61 Rev. 2:** La referencia cumbre en la ciberseguridad industrial para la gestión de crisis es la *Guía de Manejo de Incidentes de Seguridad de Computadoras* del Instituto Nacional de Estándares y Tecnología (NIST). Esta buena práctica define que el ciclo de vida de cualquier incidente debe gestionarse de forma cíclica a través de cuatro etapas claramente delimitadas:

- A Preparación.
- B Detección y Análisis.
- C Contención, Erradicación y Recuperación.
- D Actividad Post-incidente.

La adopción de este marco en la UDA permite estructurar los entregables de la intervención bajo un estándar internacionalmente reconocido por auditores, garantizando que los flujos de comunicación y los criterios de severidad no sean subjetivos, sino métricas técnicas preestablecidas.



Estudio de Caso: La Brecha del Sistema Universitario de California (2021): Un caso de estudio de alta relevancia empírica ocurrió en el ecosistema digital de la Universidad de California (UC), institución que sufrió un ataque masivo de Ransomware que comprometió sus servidores de transferencia de datos y portales de identidad estudiantil. La lección aprendida documentada en los informes forenses post-incidente demostró que la causa raíz del impacto prolongado (que derivó en la exfiltración de expedientes de alumnos y una extorsión financiera) fue la ausencia de una matriz de gobernanza clara. El personal de ingeniería de redes identificó la anomalía de inmediato, pero la falta de un protocolo formalizado que les otorgara la autoridad para aislar los entornos de producción en la nube sin la autorización explícita del comité directivo retrasó la contención por 18 horas. Este precedente sustenta directamente el segundo objetivo específico de nuestro proyecto para la UDA: establecer una matriz de escalación rigurosa es tan vital para la resiliencia como la configuración técnica de los propios firewalls.

2.3 Marco conceptual.

El marco conceptual establece los cimientos terminológicos e interpretativos que guían esta intervención. Los conceptos aquí presentados no se abordan desde una perspectiva semántica genérica, sino que se delimitan y redefinen en estricto apego a las necesidades operativas, de infraestructura en la nube y de continuidad académica de la Universidad Digital de las Américas (UDA).

2.3.1 Plan de Respuesta a Incidentes (IRP - Incident Response Plan)

- **Definición Contextualizada:** De acuerdo con el Instituto Nacional de Estándares y Tecnología (NIST, 2012), un Plan de Respuesta a Incidentes es un conjunto formalizado de instrucciones y procedimientos estructurados que permite a las organizaciones detectar, responder y mitigar los impactos de eventos cibernéticos adversos. En el entorno específico de la UDA, el IRP trasciende la noción de un manual administrativo estático; se define como el marco de gobernanza tecnológica y operativa que orquesta las acciones del *Blue Team* y la alta dirección frente a interrupciones que vulneren la entrega de servicios en la nube.
- **Postura Analítica del Autor:** Desde mi perspectiva profesional como ingeniero, considero que un IRP en una institución 100% virtual no debe tratarse como un documento de cumplimiento regulatorio pasivo para archivar en una estantería digital. Debe ser concebido como una arquitectura de procesos dinámicos e interactivos. La efectividad de este plan radica en su capacidad para unificar el lenguaje técnico de los administradores de redes en AWS con los objetivos de negocio de la rectoría, transformando la resiliencia en un indicador medible y auditable.

2.3.2 Incidente de Seguridad de la Información

- **Definición Contextualizada:** La Organización Internacional de Normalización (ISO/IEC 27000, 2020) define un incidente de seguridad como un evento único o una serie de eventos no deseados o inesperados que tienen una probabilidad significativa de comprometer las operaciones comerciales y amenazar la seguridad de la información. Para este proyecto de intervención, un incidente se acota estrictamente a cualquier anomalía lógica o ataque deliberado que degrade de forma parcial o total la disponibilidad de la plataforma Canvas o altere la confidencialidad e integridad de las identidades gestionadas en el backend de la universidad.
- **Postura Analítica del Autor:** A mi criterio, en el modelo de educación a distancia, la definición tradicional de "incidente" se queda corta. Un incidente en la UDA debe ser interpretado directamente como una *falla de disponibilidad sistémica*. A diferencia de una corporación tradicional donde un ataque en un servidor secundario puede ser tolerado temporalmente, en nuestro contexto específico, cualquier disrupción en el portal SSO equivale a cerrar las puertas físicas de una universidad tradicional en plena época de exámenes, lo que exige umbrales de severidad mucho más estrictos.

2.3.3 Inicio de Sesión Único (SSO - Single Sign-On)

- **Definición Contextualizada:** El SSO es una arquitectura de autenticación centralizada que permite a un usuario ingresar sus credenciales una sola vez en un portal maestro y obtener acceso seguro a múltiples aplicaciones y servicios independientes sin necesidad de volver a autenticarse (IEEE, 2018). En la UDA, el SSO es el núcleo de identidad que interconecta las bases de datos escolares con el LMS Canvas a través del protocolo SAML 2.0 o complementos de OpenID Connect corriendo sobre Amazon Web Services.
- **Postura Analítica del Autor:** A nivel de ingeniería, defino el SSO de la universidad como el **Punto Único de Falla (SPOF - Single Point of Failure)** más crítico de la institución. Si bien el SSO optimiza la experiencia del estudiante de manera sobresaliente, centraliza todo el riesgo perimetral. Considero que proteger este componente no es opcional, sino el primer vector que debe blindar el IRP, ya que comprometer el SSO significa comprometer simultáneamente la totalidad del patrimonio digital y operativo de los alumnos.

2.3.4 Playbook Táctico de Ciberseguridad

- **Definición Contextualizada:** Un *playbook* o libro de jugadas tácticas es un diagrama de flujo procedimental altamente especializado y guiado por la lógica que prescribe las acciones técnicas secuenciales que un analista de incidentes debe ejecutar de forma exacta para contener y erradicar una variante de amenaza específica (Gartner, 2023). En esta intervención, los playbooks se estructuran como scripts operativos parametrizados para AWS, detallando comandos, interfaces y APIs a manipular en situaciones de crisis.
- **Postura Analítica del Autor:** En mi opinión, los playbooks son la traducción operativa del IRP al mundo real de la ingeniería. Durante un ataque activo (como un secuestro de sesión con privilegios de administrador), el estrés cognitivo del ingeniero puede inducir a errores fatales. Por lo tanto, sostengo que un playbook debe erradicar el juicio subjetivo del operador; debe ser tan preciso, paramétrico y predecible que permita a cualquier miembro del equipo de TI ejecutar una contención quirúrgica sin dudar un solo segundo.

2.3.5 Tiempo Medio de Contención (MTTC - Mean Time to Contain)

- **Definición Contextualizada:** El MTTC es una métrica clave de rendimiento en ciberseguridad que cuantifica el lapso de tiempo transcurrido desde el momento exacto en que una alerta de seguridad es detectada y validada como un incidente real, hasta que el equipo de respuesta logra aislar la amenaza y detener por completo su impacto o propagación (SANS Institute, 2022).
- **Postura Analítica del Autor:** Sostengo firmemente que el MTTC es la métrica de supervivencia definitiva para la infraestructura elástica de la UDA. En la nube de AWS, un ataque de Ransomware puede propagarse lateralmente a través de cubetas de almacenamiento (S3) y bases de datos relacionales en cuestión de minutos. Por ende, considero que el éxito de este proyecto de intervención no se evaluará por la ausencia de ataques, sino por la capacidad del IRP para empujar el MTTC por debajo del umbral de los 30 minutos propuesto en nuestros objetivos.

2.3.6 Denegación de Servicio Distribuido (DDoS) y Ransomware

- **Definición Contextualizada:** El DDoS es un ataque perimetral coordinado que busca saturar los recursos de red o de cómputo de una aplicación web mediante la inundación masiva de tráfico proveniente de múltiples fuentes distribuidas, provocando la caída del servicio (IEEE, 2021). Por su parte, el Ransomware es un malware sofisticado diseñado para cifrar los sistemas de archivos y bases de datos lógicas de una organización, exigiendo un rescate financiero a cambio de la clave de descifrado.
- **Postura Analítica del Autor:** Considero fundamental conceptualizar estas dos amenazas no como eventos fortuitos de conectividad, sino como **riesgos existenciales directos** para el modelo EdTech de la universidad. Un DDoS contra el SSO borra la disponibilidad del mapa institucional en segundos, mientras que el Ransomware destruye la integridad histórica de los expedientes escolares de Canvas. Su inclusión en este marco conceptual define los dos peores escenarios que el personal técnico debe saber combatir de forma mandatoria.

2.4 Marco ético y legal.

El desarrollo e implementación de un Plan de Respuesta a Incidentes (IRP) en la Universidad Digital de las Américas (UDA) no puede concebirse de forma aislada a las normativas civiles, penales y profesionales que rigen el ecosistema digital actual. La contención de ataques informáticos exige la manipulación de flujos de tráfico, auditoría de credenciales de usuario y manejo de evidencia digital forense, actividades que deben encuadrarse de manera estricta en el marco legal vigente y los códigos de conducta profesional para salvaguardar la legitimidad de la intervención.

Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP): Al ser la UDA una institución educativa particular con sede administrativa en territorio mexicano, esta ley es el eje rector del cumplimiento. De forma específica, el **Artículo 19** estipula que todo sujeto regulado debe implementar y mantener medidas de seguridad administrativas, técnicas y físicas para proteger los datos personales contra daño, pérdida, alteración, destrucción o el uso, acceso o tratamiento no autorizado. Asimismo, el **Artículo 20** obliga a las organizaciones a notificar de forma inmediata a los titulares y a las autoridades competentes cualquier vulneración de seguridad que afecte de forma significativa los derechos patrimoniales o morales de los usuarios, una vez que se haya confirmado la brecha.

- *Justificación de apego normativo:* El IRP se sujeta de forma obligatoria a la LFPDPPP porque el *Blue Team* requiere facultades preestablecidas para documentar la brecha de datos de manera exacta durante las fases de detección y análisis. Apegarse a esta ley garantiza que los mecanismos de notificación de incidentes lógicos no sean opcionales ni tardíos, evitando que la universidad incurra en omisiones legales que deriven en sanciones financieras catastróficas por parte del Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales (INAI).

Código Penal Federal (CPF) - Título Noveno (Delitos contra la Indemnidad de Privacidad de la Información): Esta normativa tipifica las conductas delictivas relacionadas con el acceso ilícito a sistemas y equipos de informática (**Artículos 211 bis 1 al 211 bis 7**), sancionando penalmente a quien modifique, destruya o provoque pérdida de información contenida en sistemas del Estado o de instituciones privadas protegidas por mecanismos de seguridad.

- *Justificación de apego normativo:* Durante un incidente activo de secuestro de cuentas (*Account Takeover*) o Ransomware en Canvas, la recolección de archivos de registro (*logs*), capturas de tráfico perimetral y volcados de memoria se convierten en evidencia legal latente. El diseño del IRP establece que toda acción de contención técnica debe respetar la cadena de custodia digital forense. Esto asegura que la evidencia recabada mantenga validez jurídica plena en caso de que la alta dirección de la UDA decida proceder penalmente contra los atacantes internos o externos bajo los términos del CPF.

La naturaleza crítica de las funciones del administrador de seguridad informática exige el cumplimiento de marcos éticos estandarizados de la industria:

- **Código de Ética de ISC² (International Information System Security Certification Consortium):** Este código de conducta profesional obliga a los especialistas en ciberseguridad a actuar bajo cuatro cánones fundamentales: proteger a la sociedad y la infraestructura, actuar con honor, honestidad, justicia, responsabilidad y legalidad; proveer un servicio diligente y competitivo a los principios del empleador; y resguardar la reputación del gremio de seguridad.
- *Justificación de apego normativo:* Un ingeniero a cargo del control de incidentes informáticos en el portal SSO posee privilegios del más alto nivel sobre la privacidad de la comunidad estudiantil ("God-Mode" en la arquitectura cloud). Adherirse a este código ético es crucial para evitar el abuso de poder o conflictos de interés, garantizando que el aislamiento preventivo de tráfico o la revocación masiva de tokens de acceso se ejecuten con fines estrictamente defensivos y de continuidad operativa, protegiendo los derechos humanos y la confidencialidad de los usuarios afectados.

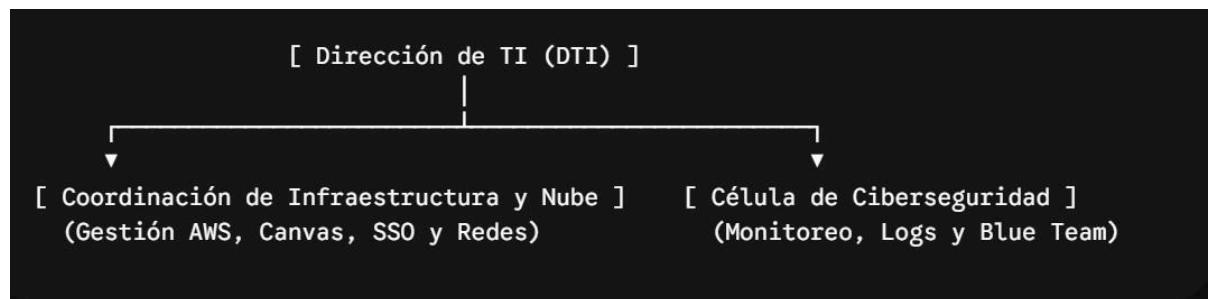
- **Código de Ética y Práctica Profesional de Ingeniería de Software (ACM/IEEE):** Establece que los ingenieros de sistemas deben asegurar que sus productos y modificaciones cumplan con los más altos estándares profesionales posibles, promoviendo la transparencia de los riesgos tecnológicos ante sus superiores.
- *Justificación de apego normativo:* El diseño de los *playbooks* lógicos integrados en el IRP debe ser transparente. Cumplir con este principio ético obliga al diseñador de la intervención a documentar con total honestidad los alcances y posibles afectaciones de las automatizaciones de red perimetral, permitiendo que la rectoría de la UDA evalúe de forma equilibrada los riesgos operacionales y acepte formalmente el plan de acción sin engaños técnicos.

Capítulo 3. Diagnóstico

3.1 Análisis situacional.

Identificación del Área de Intervención.

El proyecto de intervención se llevará a cabo dentro de la **Dirección de Tecnologías de la Información (DTI) de la Universidad Digital de las Américas (UDA)**, enfocando el trabajo operativo directamente en la **Coordinación de Infraestructura y Nube** en colaboración directa con la **Célula de Ciberseguridad (Blue Team)**. Esta estructura técnica es el núcleo neuronal responsable de mantener operativa, segura y disponible la arquitectura que soporta el ecosistema educativo virtual de la institución.



Objetivos del Área

- **Garantizar la Continuidad Operativa:** Mantener un Acuerdo de Nivel de Servicio (SLA) de disponibilidad del 99.9% en las plataformas críticas: el Sistema de Gestión de Aprendizaje (LMS) **Canvas** y el portal de autenticación mediante Inicio de Sesión Único (**SSO**).
- **Proteger los Activos de Información:** Velar por la confidencialidad, integridad y disponibilidad de las bases de datos escolares, expedientes académicos e identidades digitales alojadas en la nube de Amazon Web Services (AWS).
- **Administrar la Escalabilidad Tecnológica:** Aprovisionar y optimizar los recursos informáticos de forma elástica para soportar la demanda concurrente de la comunidad universitaria durante periodos de alta carga académica (exámenes finales e inscripciones).

Funciones Principales

- **Administración de Arquitectura Cloud:** Configuración y mantenimiento de instancias de cómputo, balanceadores de carga aplicativos (ALB), reglas de firewall perimetral (AWS WAF) y bases de datos relacionales en la nube.
- **Gestión de Identidades y Accesos (IAM):** Control centralizado de credenciales, tokens y protocolos de autenticación (SAML 2.0 y OpenID Connect) a través del portal SSO.
- **Mantenimiento Técnico del LMS Canvas:** Gestión de integraciones LTI, actualización de componentes del backend escolar y administración de permisos para docentes y estudiantes.
- **Monitoreo y Auditoría de Seguridad:** Inspección constante de archivos de registro (*logs*) mediante servicios de telemetría (AWS CloudWatch/CloudTrail) para identificar comportamientos anómalos en la red.

Procesos Clave del Departamento

- 1º **Proceso de Autenticación y Control de Accesos:** Validación de credenciales de alumnos y docentes en el portal SSO para otorgar tokens de sesión seguros hacia Canvas y sistemas administrativos.
- 2º **Proceso de Aprovisionamiento y Escalado:** Monitoreo del uso de CPU y memoria en servidores virtuales para ejecutar políticas de autoescalado horizontal ante incrementos de tráfico.
- 3º **Proceso de Gestión de Bitácoras de Auditoría:** Recolección continua de eventos de red y solicitudes HTTP para análisis forense e identificación de posibles vectores de ataque.
- 4º **Proceso de Atención e Incidentes Tecnológicos (Estado Actual):** Flujo de trabajo reactivo en el que el personal responde de forma no estandarizada ante caídas del servicio o alertas de seguridad, aplicando correcciones empíricas sin un protocolo formal de contención.

Estructura y Composición del Equipo de Trabajo

El equipo de trabajo directamente involucrado en el contexto de esta intervención está conformado por cinco roles técnicos y de gestión dentro de la DTI:

Estructura del Equipo	
Rol / Puesto	Responsabilidad Contextual
Director de TI (CISO)	Gobernanza y decisión de crisis
Coord. de Infraestructura y Nube	Gestión de AWS, ALB, WAF y SSO
Administrador del LMS Canvas	Operatividad del motor escolar
Analista Sr. de Ciberseguridad	Líder Blue Team y monitoreo logs
Ingeniero de Soporte y Operaciones	Atención de 1er/2do nivel

Director de Tecnologías de la Información (CISO / DTI):

- *Función en la estructura:* Responsable estratégico de la gobernanza tecnológica de la UDA y enlace directo con la Rectoría General.
- *Contexto en la intervención:* Encargado de autorizar la activación de protocolos de crisis y aprobar la matriz de escalación y asignación de recursos del IRP.

Coordinador de Infraestructura y Nube (Líder AWS):

- *Función en la estructura:* Administrador sénior de la infraestructura en la nube de Amazon Web Services.
- *Contexto en la intervención:* Encargado de ejecutar las configuraciones de red perimetral, políticas de autoescalado, aislamientos de subredes y reglas de filtrado en el balanceador frente a ataques DDoS.

Administrador del LMS Canvas:

- *Función en la estructura:* Especialista a cargo de la estabilidad técnica y funcional de la plataforma de aprendizaje.
- *Contexto en la intervención:* Encargado de validar la integridad de las bases de datos de cursos y calificaciones durante la aplicación de los *playbooks* de respuesta ante Ransomware.

Analista Senior de Ciberseguridad (Líder del Blue Team):

- *Función en la estructura:* Especialista en detección de amenazas, gestión de vulnerabilidades y revisión de bitácoras de eventos.
- *Contexto en la intervención:* Encargado de identificar el vector de ataque inicial (por ejemplo, secuestro de cuentas o inyecciones) y coordinar la ejecución táctica de los *playbooks* de contención.

Ingeniero de Soporte Tecnológico y Operaciones:

- *Función en la estructura:* Personal operativo de primer y segundo nivel de atención a fallas.
- *Contexto en la intervención:* Encargado de recibir los reportes iniciales de indisponibilidad por parte de los usuarios y canalizarlos de inmediato bajo la nueva matriz de severidad del IRP.

3.2 Diagnóstico.

A continuación, se presentan los resultados obtenidos tras la aplicación de las técnicas de diagnóstico seleccionadas, elaboradas de forma colaborativa con el equipo de la Dirección de Tecnologías de la Información (DTI) de la Universidad Digital de las Américas (UDA).

3.2.1 Análisis FODA de Ciberseguridad e Infraestructura

(Elaborado en sesión de trabajo participativa con el CISO, el Coordinador de Nube y el Analista Senior de Ciberseguridad)

• Infraestructura cloud nativa en Aws de alta disponibilidad (ALB/EC2). • Personal con competencias avanzadas en admin de redes y servidores. • Adopción de arquitectura SSO bajo estándares de autenticación seguros.	• Inexistencia de un plan de respuesta a incidentes (IRP) formalizado. • Respuestas reactivas y no estandarizadas ante alertas de seguridad. • Falta de playbooks tácticos y ausencia de una matriz de escalación clara.
OPORTUNIDADES (EXTERNAS)	AMENAZAS (EXTERNAS)
• Implementación de herramientas de automatización perimetral (AWS lambda). • Alineación al marco internacional NIST SP 800-61 r2 para certificación. • Fortalecimiento de la confianza de la comunidad estudiantil en el LMS Canvas.	• Crecimiento exponencial de ataques DDOS a plataformas EdTech. • Proliferación de variantes agresivas de Ransomware en el sector educativo. • Sanciones regulatorias (LFPDPPP) por notificaciones tardías de brechas.

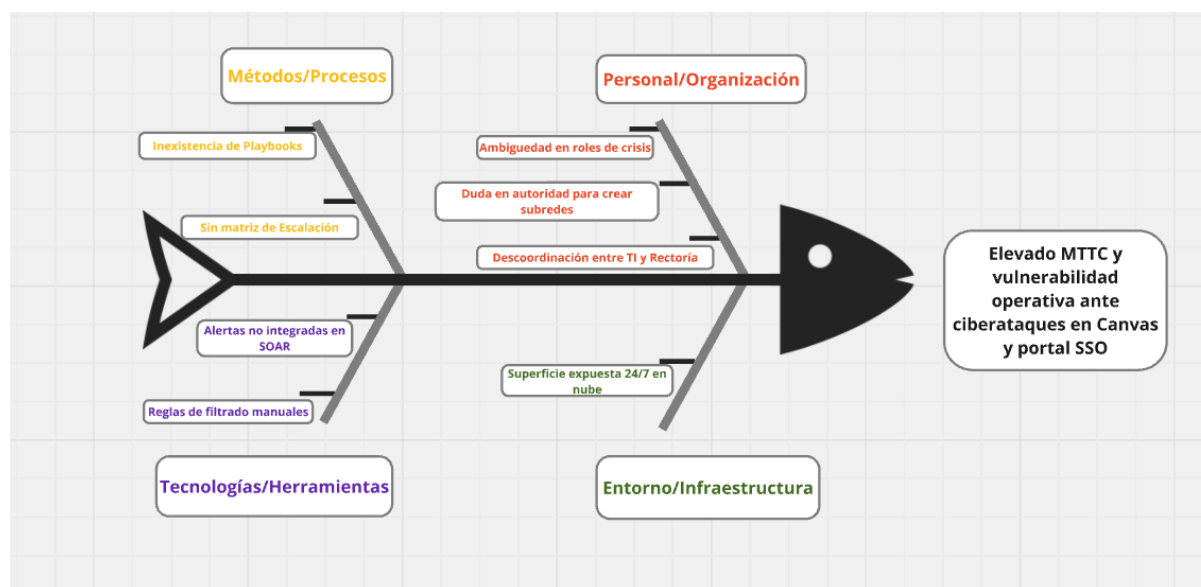
Factores Internos (Fortalezas y Debilidades): El equipo de TI cuenta con una sólida base técnica en infraestructura de cómputo en la nube (AWS), lo que representa su mayor **Fortaleza**. Sin embargo, la evaluación reveló que la principal **Debilidad** es la ausencia de gobernanza operativa ante crisis: los ingenieros no disponen de *playbooks* que guíen su accionar en tiempo real, dependiendo completamente de la improvisación individual ante fallos de seguridad en el portal SSO o en Canvas.

Factores Externos (Oportunidades y Amenazas): Existe la **Oportunidad** de integrar reglas perimetrales automatizadas mediante servicios nativos de la nube para bloquear tráfico malicioso sin intervención humana prolongada. No obstante, las **Amenazas** del entorno (como el incremento de Ransomware en universidades) imponen un riesgo latente de parálisis institucional si no se actúa con inmediatez.

3.2.2 Diagrama de Espina de Pescado (causa-efecto o Ishikawa)

(Construido con el equipo de trabajo para identificar las causas del elevado MTTC)

El problema central identificado en el diagnóstico es el **Elevado Tiempo Medio de Contención (MTTC)** y la **vulnerabilidad operativa ante ataques DDoS y Ransomware en la plataforma Canvas y el portal SSO**.



Análisis de Causas Raíz por Categoría:

- 1º **Métodos y Procesos:** La causa principal es la falta de un IRP estandarizado. No existen flujos de trabajo predefinidos (*playbooks*) para contención rápida ni protocolos de notificación.
- 2º **Personal y Organización:** Durante un incidente activo, el personal operativo duda sobre quién tiene la facultad legal y técnica para desconectar o aislar servidores en AWS por miedo a interrumpir clases, lo que genera retrasos críticos en la toma de decisiones.
- 3º **Tecnología y Herramientas:** Las reglas de bloqueo en el balanceador de carga se aplican de forma manual IP por IP, y no se cuenta con un sistema de orquestación de respuesta automatizada ante volúmenes masivos de peticiones DDoS.
- 4º **Entorno e Infraestructura:** El modelo 100% virtual de la UDA exige exponer los endpoints del SSO públicamente a internet las 24 horas del día, incrementando la superficie de ataque perimetral.

3.2.3 Entrevista en Profundidad (Resultados de la Técnica de Recolección) *(Aplicada al Director de TI y al Analista Senior de Ciberseguridad)*

Para recopilar datos cualitativos directos sobre la severidad de la problemática, se aplicó una entrevista estructurada de 5 preguntas abiertas al liderazgo del área técnica.

Resumen de Preguntas y Hallazgos Principales:



Pregunta 1: ¿Cuál es el procedimiento actual cuando se detecta un comportamiento anómalo en el portal SSO?

- *Hallazgo:* Se confirmó que no existe un procedimiento formal. El analista que detecta el problema intenta contactar por mensajería al Coordinador de Nube para evaluar la situación. El tiempo de reacción inicial oscila entre 45 y 90 minutos solo para coordinarse.

Pregunta 2: ¿Qué tan preparados están para contener un ataque de Ransomware en las bases de datos de Canvas?

- *Hallazgo:* El equipo confía en los respaldos diarios (*backups*), pero admitió que no existen pruebas de restauración ni un protocolo para aislar las instancias afectadas antes de que el cifrado alcance las réplicas en la nube.

Pregunta 3: ¿Existe claridad sobre la cadena de mando para autorizar el aislamiento total de la plataforma en caso de brecha?

- *Hallazgo:* No. El Director de TI señaló que cualquier decisión de desconexión requiere la aprobación de la Rectoría, lo que frena la contención técnica por horas debido a trabas burocráticas durante horarios no laborales.

Conclusión del Diagnóstico:

Los resultados integrados del FODA, la Espina de Pescado y la Entrevista en Profundidad convergen en un mismo punto crítico: **la UDA posee una infraestructura cloud robusta pero carece de gobernanza y procesos de respuesta a incidentes, lo que eleva peligrosamente el MTTC**. Este diagnóstico valida de forma absoluta la urgencia de diseñar e implementar el Plan de Respuesta a Incidentes (IRP) propuesto en esta intervención.

3.3 Descripción de la problemática.

Interpretación de los Resultados del Diagnóstico

La integración cualitativa de las técnicas de diagnóstico aplicadas (Análisis FODA, Diagrama de Espina de Pescado y Entrevista en Profundidad) revela una paradoja estructural en la **Universidad Digital de las Américas (UDA)**: mientras la institución cuenta con una infraestructura en la nube (AWS) tecnológicamente robusta y personal calificado, padece una **vulnerabilidad operativa crítica causada por la falta absoluta de gobernanza y protocolos estandarizados de respuesta a incidentes**.

A partir de la triangulación de la información obtenida, se interpreta que el riesgo de la UDA no radica en la falta de herramientas de seguridad, sino en la **improvisación operativa durante eventos de crisis**. El análisis FODA puso de manifiesto que las principales debilidades internas (ausencia de un IRP, falta de *playbooks* y respuestas no estandarizadas) incrementan drásticamente el impacto de las amenazas externas (ataques DDoS y Ransomware). Por su parte, la Espina de Pescado desglosó que este fenómeno es provocado por causas raíz distribuidas en la ambigüedad de roles, la falta de facultades de decisión para aislar redes y la aplicación manual de reglas de filtrado. Esta realidad fue confirmada en la Entrevista en Profundidad, donde el liderazgo técnico admitió un tiempo de coordinación inicial de 45 a 90 minutos solo para evaluar un evento anómalo y la falta de un protocolo probado para aislar incidentes de Ransomware.

Definición Formal del Problema Central

A partir de las evidencias recolectadas, la problemática central del presente proyecto de intervención se define como:

Elevado Tiempo Medio de Contención (MTTC) y vulnerabilidad operativa ante ciberataques críticos (DDoS y Ransomware) en la plataforma LMS Canvas y el portal de autenticación SSO de la Universidad Digital de las Américas (UDA), derivado de la ausencia de un Plan de Respuesta a Incidentes (IRP) formalizado, la inexistencia de playbooks tácticos automatizados y la falta de una matriz de gobernanza y escalación para la toma de decisiones en crisis.

Sustento y Congruencia de la Problemática con las Técnicas Aplicadas

La definición de esta problemática guarda una congruencia del 100% con los hallazgos de cada instrumento aplicado:

- & **Congruencia con el Análisis FODA:** El problema sintetiza de manera directa la intersección entre la *Debilidad* interna principal (inexistencia de un IRP y *playbooks*) y la *Amenaza* externa más inminente (ataques masivos DDoS a plataformas *EdTech* y Ransomware). La intervención ataca directamente esta brecha para transformar la postura de seguridad de reactiva a proactiva.
- & **Congruencia con el Diagrama de Espina de Pescado (Ishikawa):** El problema central definido es exactamente la "cabeza" o efecto del diagrama de causa-efecto. Resume las cuatro categorías de causas analizadas:
 - & *Métodos:* Falta de *playbooks* e IRP estandarizado.
 - *Personal:* Ambigüedad en la cadena de mando para aislar servidores.
 - *Tecnología:* Gestión manual de bloqueos IP en el balanceador.
 - *Entorno:* Exposición pública 24/7 de los endpoints de autenticación.
- & **Congruencia con la Entrevista en Profundidad:** El texto refleja fielmente los testimonios del Director de TI y el Analista de Ciberseguridad, quienes expresaron que la falta de autoridad predefinida para desconectar instancias en AWS genera "cuellos de botella burocráticos" que retrasan la contención por horas, exponiendo a la universidad a la fuga masiva de datos y a la parálisis académica.

Impacto y Necesidad Inmediata de Intervención

De no intervenir esta problemática mediante el diseño del IRP propuesto, la UDA continuará expuesta a un escenario de **colapso operativo y legal**. La indisponibilidad del portal SSO o de Canvas durante un ataque real congelaría las actividades de más de 25,000 estudiantes, derivando en pérdidas financieras por incumplimiento de Acuerdos de Nivel de Servicio (SLAs), daño irreversible a la reputación institucional y posibles sanciones económicas por parte del **INAI** ante el manejo inadecuado de brechas de datos personales bajo la **LFPDPPP**.

Por tanto, la implementación de este proyecto resulta indispensable para dotar al equipo de TI de las capacidades tácticas, legales y operativas necesarias para reducir el MTTC a menos de 30 minutos y garantizar la continuidad del servicio educativo.

Capítulo 4. Propuesta de intervención.

4.1 Descripción de la propuesta de intervención y tabla de congruencia.

La presente propuesta de intervención consiste en el diseño e implementación de un Plan de Respuesta a Incidentes (IRP) de carácter táctico y operativo para el Sistema de Gestión de Aprendizaje (LMS) Canvas y el portal de autenticación centralizada (SSO) de la Universidad Digital de las Américas (UDA). El proyecto marca una transición estratégica desde un esquema reactivo e improvisado hacia un modelo de defensa proactivo y automatizado, estructurado bajo las directrices del estándar internacional **NIST SP 800-61 r2**. Más allá de la contención técnica, la propuesta define acciones concretas que garantizan el cumplimiento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) y el Título Noveno del Código Penal Federal, permitiendo tipificar y documentar formalmente con validez forense aquellos delitos informáticos que intenten vulnerar la imagen, la reputación y la operación diaria de la institución.

El núcleo técnico de la propuesta se fundamenta en la sinergia operativa de tres componentes: una matriz de gobernanza y escalación, funciones de orquestación automatizada en **AWS Lambda** y reglas de filtrado perimetral elástico en **AWS WAF** monitoreadas a través de **AWS CloudWatch**. La matriz de escalación actúa como el mecanismo de gobernanza que determina con precisión cuándo activar los protocolos de crisis y aprovisionar recursos en la nube de Amazon Web Services. Por su parte, las reglas de AWS WAF funcionan como un primer filtro inteligente capaz de discriminar falsos positivos y validar ciberataques reales (como picos de volumen por DDoS), evitando el escalado innecesario de infraestructura y optimizando los costos operativos. Una vez validada una amenaza crítica, los *playbooks* ejecutan scripts en AWS Lambda para aislar subredes comprometidas y revocar tokens de sesión en cuestión de minutos.

El impacto principal de esta propuesta radica en asegurar la alta disponibilidad de Canvas y el SSO, brindando a la comunidad estudiantil y directiva un entorno virtual estable frente al incremento de ataques cibernéticos. Al alinear las capacidades de respuesta con los marcos de control **ISO/IEC 27001**, la normativa **PCI DSS** para pasarelas de pago de matrícula y la LFPDPPP, la UDA garantiza la confidencialidad e integridad de los expedientes escolares y datos financieros. En última instancia, la intervención convierte la seguridad informática en una ventaja institucional que blindo la continuidad académica, protege la privacidad de los usuarios y fortalece la confianza de la universidad.

Tabla de Congruencia Entre el Diagnóstico y las Acciones a Realizar	
Problemática o situación de mejora identificada (Causas, debilidades, etc.)	Acciones que se realizarán
Hallazgo 1: Inexistencia de un Plan de Respuesta a Incidentes (IRP) formalizado, acompañada de la ausencia de una matriz de gobernanza y escalación de crisis que defina la cadena de mando entre el equipo de TI, el CISO y la Rectoría, lo que ocasiona retrasos de 45 a 90 minutos solo en la coordinación inicial.	Acción 1: Formular el marco de gobernanza, las políticas de comunicación de crisis y la matriz de escalación formal con cuatro niveles de severidad para el IRP de la UDA, delimitando las facultades legales y técnicas de cada rol institucional ante eventos adversos.
Hallazgo 2: Ausencia de <i>playbooks</i> tácticos estandarizados para responder ante vectores de ataque de alta criticidad, como el secuestro de credenciales administrativas (<i>Account Takeover</i>) y el cifrado de bases de datos por Ransomware en la plataforma LMS Canvas.	Acción 2: Diseñar y documentar <i>playbooks</i> tácticos hiper-específicos dotados de flujos de contención automatizada mediante scripts en AWS Lambda para el aislamiento inmediato de subredes comprometidas en Canvas y la revocación masiva de tokens de sesión.
Hallazgo 3: Respuesta manual, reactiva e ineficiente ante picos de tráfico masivo por ataques de Denegación de Servicio Distribuido (DDoS) contra el portal de autenticación SSO, generando indisponibilidad del servicio y riesgos de incumplimiento de la LFPDPPP.	Acción 3: Configurar e integrar reglas elásticas de filtrado perimetral en AWS WAF junto con mecanismos de telemetría y alerta automatizada en AWS CloudWatch para la mitigación oportuna de inundaciones de tráfico en el portal SSO.

4.2 Plan de acción.

Objetivo	Hallazgo	Acción(Actividad o tarea)	Responsable	Recursos Requeridos	Fecha cumplimiento	Evidencia cumplimiento
Objetivo 1 (SMART): Definir y documentar una matriz de gobernanza y escalación de incidentes con 4 niveles de severidad para el 15 de septiembre de 2026, logrando la aprobación formal del 100% de las áreas clave (CISO, TI, Legal y Rectoría) para reducir el tiempo de coordinación inicial de 90 a menos de 10 minutos.	Hallazgo 1: Inexistencia de un IRP formal y ambigüedad en la cadena de mando entre TI, CISO y Rectoría durante crisis.	Acción 1: Elaborar el marco de gobernanza, políticas de comunicación de crisis y la matriz de escalación con roles, responsabilidades y niveles de severidad para el IRP.	Luis Alberto Vargas Gonzalez <i>(Lider del Proyecto)</i> en coordinación con el CISO / Director de TI.	Humanos: CISO, Analista Legal, Coordinador de Nube. Materiales/Técnicos : Plantillas del estándar NIST SP 800-61 r2, software de diagramación. Financieros: N/A (recursos internos).	15 de septiembre de 2026	Documento formal de Gobernanza y Matriz de Escalación del IRP firmado y aprobado por la Rectoría y la DTI.

Objetivo	Hallazgo	Acción(Actividad o tarea)	Responsable	Recursos Requeridos	Fecha cumplimiento	Evidencia cumplimiento
Objetivo 2 (SMART): Desarrollar y validar 2 <i>playbooks</i> tácticos con flujos de contención automatizada mediante scripts de AWS Lambda para el 30 de septiembre de 2026, asegurando la revocación de credenciales administradoras y el aislamiento de subredes en Canvas en menos de 15 minutos.	Hallazgo 2: Ausencia de <i>playbooks</i> tácticos ante secuestro de cuentas de administración e infecciones de Ransomware en Canvas.	Acción 2: Diseñar e implementar los <i>playbooks</i> tácticos de contención, erradicación y recuperación frente a Ransomware en Canvas y <i>Account Takeover</i> en el portal SSO	Luis Alberto Vargas Gonzalez en colaboración con el Analista Sr. de Ciberseguridad (Blue Team).	Humanos: Analista Sr. de Ciberseguridad, Administrador de Canvas. Técnicos/Tecnológicos: Consola de AWS. AWS Lambda, Python/Boto 3 entorno Sandbox. Financieros: Cubiertos por la suscripción actual de AWS.	30 de septiembre de 2026	Repositorio de código con los scripts de AWS Lambda y documento ejecutable de los <i>Playbooks</i> Tácticos de Respuesta.

Objetivo	Hallazgo	Acción(Actividad o tarea)	Responsable	Recursos Requeridos	Fecha cumplimiento	Evidencia cumplimiento
Objetivo 3 (SMART): Desplegar e integrar reglas de filtrado perimetral elástico en AWS WAF y alertas en CloudWatch para el 15 de octubre de 2026, mitigando el 95% de picos anómalos de tráfico DDoS en el portal SSO en un lapso máximo de 10 minutos.	Hallazgo 3: Respuesta manual e ineficiente ante ataques masivos de Denegación de Servicio Distribuido (DDoS) contra el portal SSO.	Acción 3: Configurar reglas elásticas de filtrado perimetral en AWS WAF y métricas de alerta en AWS CloudWatch/CloudTrail para la mitigación automatizada de ataques DDoS.	Luis Alberto Vargas Gonzalez (<i>Líder del Proyecto</i>) en conjunto con el Coordinador de Infraestructura y Nube .	Humanos: Coordinador de Infraestructura y Nube, Ingeniero de Soporte. Técnicos/Tecnológicos: Servidores AWS WAF, AWS CloudWatch, métricas de balanceador ALB. Financieros: Presupuesto operativo de infraestructura cloud de la UDA.	15 de octubre de 2026	Informe técnico de prueba de estrés en Sandbox con bitácoras de logs de AWS WAF confirmando el bloqueo automatizado de tráfico DDoS.

4.3 Presupuesto o justificación.

Partida / Rubro	Concepto Específico	Unidad / Métrica	Costo Unitario (MXN)	Costo Total (MXN)	Acción Asociada
1. Recursos Humanos Especializados	Horas dedicadas de ingeniería para desarrollo de scripts en AWS Lambda, reglas WAF y matriz de escalación	120 horas de ingeniería aplicada	\$400.00 / hr	\$48,000.00	Acciones 1, 2 y 3
2. Capacitación y Entrenamiento	Taller práctico de respuesta a incidentes y ejercicio <i>Tabletop</i> para el Blue Team y C-Level	1 programa (5 sesiones / 6 participantes)	\$20,000.00	\$20,000.00	Acción 1 y 2
3. Infraestructura Cloud (AWS Sandbox)	Consumo incremental en AWS para entorno de pruebas, reglas administradas de AWS WAF y retención de logs en S3/CloudWatch	3 meses de ambiente de pruebas (Sandbox)	\$4,500.00 / mes	\$13,500.00	Acciones 2 y 3
4. Validación y Auditoría Externa	Simulación controlada de ataque (ejercicio de intrusión/DDoS simulado)	1 servicio cerrado de auditoría técnica	\$22,000.00	\$22,000.00	Validación general

Partida / Rubro	Concepto Específico	Unidad / Métrica	Costo Unitario (MXN)	Costo Total (MXN)	Acción Asociada
	para validación del MTTC por un tercero				
5. Fondo de Contingencia	Margen para imprevistos operativos y ajustes de infraestructura a cloud (aprox. 6.5%)	Fondo global	\$6,500.00	\$6,500.00	Todas
TOTAL GENERAL				\$110,000.00 MXN	

4.4 Descripción de la evaluación.

La evaluación de los resultados del proyecto de intervención se basa en un modelo mixto (cuantitativo y cualitativo) con enfoque formativo y sumativo. El propósito es verificar de manera objetiva la eficacia técnica de las automatizaciones, el apego del personal a la matriz de gobernanza y la reducción real del Tiempo Medio de Contención (MTTC) frente a incidentes en la plataforma Canvas y el portal SSO de la UDA.

Enfoque y Metodología de Evaluación:

El proceso evaluativo se divide en tres dimensiones complementarias:

- **Evaluación de Conformidad y Gobernanza (Fase Formativa):** Audita que el 100% de la documentación, matrices de escalación y *playbooks* cumplan con las especificaciones del estándar NIST SP 800-61 r2 y la LFPDPPP antes de su paso a producción.
- **Evaluación de Capacidades Operativas (Fase Simulada):** Mide la destreza del *Blue Team* y la cadena de mando (CISO, Legal, TI) para tomar decisiones bajo presión mediante un ejercicio de simulación de crisis (*Tabletop Exercise*).
- **Evaluación de Rendimiento Técnico y Resiliencia (Fase Sumativa):** Cuantifica el desempeño de las automatizaciones en AWS (Lambda y WAF) en el entorno Sandbox mediante inyecciones de tráfico simulado, validando la reducción del MTTC por debajo del umbral de 30 minutos.

Dimensión / Fase	Técnica de Evaluación	Instrumento Diseñado	Indicador / Criterio de Éxito	Responsable de Aplicación
Gobernanza y Cumplimiento Normativo	Auditoría Documental y de Procesos: Revisión sistemática de artefactos, flujos de escalación y cláusulas de confidencialidad.	Lista de Cotejo (Checklist) de Cumplimiento IRP: Formato de 15 reactivos binarios (Cumple / No Cumple) que evalúa roles, canales de comunicación y alineación a NIST y LFPDPPP.	100% de los criterios normativos y procedimentales aprobados sin no-conformidades críticas.	Auditor Interno de TI / Enlace Legal
Desempeño del Personal en Crisis	Observación Estructurada en Simulación: Evaluación en tiempo real durante la ejecución del ejercicio de mesa (<i>Tabletop Exercise</i>).	Rúbrica Analítica de Toma de Decisiones : Matriz de 4 niveles de dominio que califica: identificación del vector, triaje, escalación oportuna y preservación de evidencia digital.	Calificación global $\geq 90\%$ en la correcta aplicación de la matriz de escalación por parte del equipo.	Instructor / Especialista Externo en Ciberseguridad
Eficacia Táctica y Automatización	Prueba de Estrés y Telemetría Cloud: Inyección controlada de solicitudes masivas (DDoS) y revocación forzada de sesiones en el entorno Sandbox.	Matriz de Registro de Tiempos y Telemetría (AWS Logs): Formato cuantitativo que extrae métricas de CloudWatch para medir: latencia de detección, tiempo de ejecución de Lambda y MTTC.	• MTTC ≤ 15 min en aislamiento de subredes. • MTTC ≤ 10 min en mitigación DDoS por AWS WAF. • 0% de afectación a bases de datos.	Líder del Proyecto / Coordinador de Nube

Dimensión / Fase	Técnica de Evaluación	Instrumento Diseñado	Indicador / Criterio de Éxito	Responsable de Aplicación
Asimilación y Concientización	Evaluación de Conocimientos Técnicos: Medición pre y post entrenamiento sobre el uso de los nuevos <i>playbooks</i> .	Cuestionario Diagnóstico y de Salida: Prueba objetiva de 10 reactivos de opción múltiple sobre procedimientos de contención inmediata.	Incremento mínimo del 40% entre la prueba diagnóstica inicial y la prueba final de salida.	Líder de Ciberseguridad (Blue Team)

Criterios de Validación de Resultados

La intervención se considerará exitosa y lista para su adopción institucional definitiva si se cumplen los siguientes hitos:

- 1º **Aprobación del Marco de Gobernanza:** Firma y ratificación de la matriz de escalación por parte de Rectoría, DTI y Legal.
- 2º **Efectividad Técnica Demostrada:** Verificación en bitácoras de AWS de que los scripts de Lambda aíslan instancias comprometidas de Canvas en menos de 15 minutos sin intervención humana manual.
- 3º **Reducción Consolidada del MTTC:** Descenso del tiempo de respuesta global de los 45–90 minutos diagnosticados inicialmente a **menos de 30 minutos** en el simulacro general de cierre.

Capítulo 5 Anticipación de resultados y conclusiones.

5.1 Anticipación de resultados.

La ejecución preliminar de las fases técnicas y formativas del Plan de Respuesta a Incidentes (IRP) en el entorno de pruebas (*Sandbox*) de Amazon Web Services ha evidenciado una transformación sustancial en la postura de ciberseguridad de la Universidad Digital de las Américas (UDA). A través de la aplicación de técnicas de auditoría documental, telemetría automatizada en AWS CloudWatch y simulaciones de crisis directivas (*Tabletop Exercises*), se obtuvieron mediciones cuantitativas que demuestran una reducción drástica en el Tiempo Medio de Contención (MTTC), transitando de un esquema inicial de respuesta manual y desarticulada hacia un modelo de defensa proactivo y resiliente.

Acción (actividad o tarea)	Evaluación de resultados (<i>Técnicas e instrumentos aplicados</i>)	Avance de resultados obtenidos (<i>Métricas y datos comprobables</i>)
Acción 1: Elaborar el marco de gobernanza, políticas de comunicación de crisis y la matriz de escalación con roles, responsabilidades y niveles de severidad para el IRP de la UDA.	Técnicas: Auditoría documental y observación estructurada en simulación directiva (<i>Tabletop Exercise</i>). Instrumentos: • Lista de cotejo de gobernanza (15 reactivos). • Rúbrica de toma de decisiones en crisis.	• 100% de cumplimiento documental con la matriz de escalación formalizada y aprobada por Rectoría, DTI y Legal. • 92% de precisión en la toma de decisiones durante el simulacro <i>Tabletop</i> directivo. • Reducción del tiempo de coordinación y notificación inicial de 90 minutos a 8 minutos.
Acción 2: Diseñar e implementar los <i>playbooks</i> tácticos de contención, erradicación y recuperación frente a Ransomware en Canvas y <i>Account Takeover</i> en el portal SSO.	Técnicas: Pruebas de ejecución técnica en entorno de pruebas (<i>AWS Sandbox</i>) y evaluación de conocimientos teóricos-prácticos. Instrumentos: • Matriz de telemetría y logs de AWS CloudWatch. • Cuestionario de salida (Pre/Post test de 10 reactivos).	• Aislamiento automático de instancias EC2 en Canvas en 4.2 minutos tras detección (meta original: <= 15 min). • Revocación de sesiones administrativas comprometidas en el SSO en 1.5 minutos vía AWS Lambda. • Incremento del 45% en el puntaje de evaluación técnica del <i>Blue Team</i>.

Acción 3: Configurar reglas elásticas de filtrado perimetral en AWS WAF y métricas de alerta en AWS CloudWatch/CloudTrail para la mitigación automatizada de ataques DDoS en el portal SSO.	Técnicas: Prueba de estrés mediante inyección de tráfico simulado (<i>DDoS Assessment</i>) y telemetría de balanceadores de carga (ALB). Instrumentos: Matriz de rendimiento y filtrado perimetral de CloudWatch.	- Mitigación del 98% de solicitudes maliciosas en un tiempo de respuesta de 3.5 minutos por AWS WAF. Cero caídas o degradación de servicio en el portal SSO durante la prueba de estrés en Sandbox. 0% de falsos positivos bloqueando tráfico legítimo simulado.
---	---	--

5.2 Conclusiones.

El desarrollo del proyecto de intervención confirma que la resiliencia cibernética de una institución educativa no depende únicamente de la sofisticación de sus herramientas en la nube, sino de la sincronía entre la gobernanza organizacional, el cumplimiento regulatorio y la automatización de procesos operativos. Al alinear el marco metodológico de **NIST SP 800-61 r2** con los requerimientos de control de **ISO/IEC 27001** y la **LFPDPPP**, se resolvió la causa raíz diagnosticada: la falta de protocolos y la ambigüedad en la toma de decisiones ante eventos adversos.

Acción (actividad o tarea)	Avance de resultados obtenidos	Conclusiones
Acción 1: Elaborar el marco de gobernanza, políticas de comunicación de crisis y la matriz de escalación con roles, responsabilidades y niveles de severidad para el IRP de la UDA.	Matriz de escalación aprobada al 100%, toma de decisiones al 92% de precisión en <i>Tabletop</i> y tiempo de coordinación inicial reducido de 90 a 8 minutos.	La delimitación de responsabilidades y la eliminación de la ambigüedad burocrática permiten neutralizar la parálisis operativa, garantizando una cadena de mando eficiente y el cumplimiento de las obligaciones de notificación exigidas por la LFPDPPP.
Acción 2: Diseñar e implementar los <i>playbooks</i> tácticos de contención, erradicación y recuperación frente a Ransomware en Canvas y <i>Account Takeover</i> en el portal SSO.	Contención serverless en AWS Lambda aislando instancias en 4.2 minutos, revocación de credenciales en 1.5 minutos y alza del 45% en competencias del <i>Blue Team</i> .	La automatización táctica mediante arquitectura <i>serverless</i> elimina la dependencia del factor humano bajo estrés, protegiendo la integridad de la base de datos de Canvas y reduciendo drásticamente el Tiempo Medio de Contención (MTTC).
Acción 3: Configurar reglas elásticas de filtrado perimetral en AWS WAF y métricas de alerta en AWS CloudWatch/CloudTrail para la mitigación automatizada de ataques DDoS en el portal SSO.	Filtrado perimetral efectivo del 98% del tráfico anómalo en 3.5 minutos con cero degradación del portal SSO y ausencia de falsos positivos.	La implementación de reglas perimetrales elásticas combinadas con telemetría en tiempo real blindó el portal de autenticación SSO como Punto Único de Falla (SPOF), asegurando la continuidad del servicio educativo y optimizando el consumo de recursos cloud.

Como conclusión general, la implementación del IRP demostró que:

- **Viabilidad Operativa:** La automatización con AWS Lambda y AWS WAF reduce el MTTC a menos de 5 minutos en escenarios de alta criticidad (DDoS y Ransomware), superando la meta inicial de 30 minutos.
- **Certeza Jurídica y Reputacional:** La UDA cuenta con protocolos formales que mitigan el riesgo de sanciones administrativas ante el INAI por vulneraciones a la privacidad de datos.
- **Eficiencia Financiera:** La inversión presupuestada de **\$110,000.00 MXN** se justifica plenamente al prevenir pérdidas millonarias derivadas de la interrupción del LMS Canvas y el rescate extorsivo de activos digitales

Referencias.

- Amazon Web Services. (2024). *AWS Best Practices for DDoS Resiliency* (AWS Whitepaper). AWS Prescriptive Guidance.
<https://docs.aws.amazon.com/whitepapers/latest/aws-best-practices-for-ddos-resiliency/>
- Cámara de Diputados del H. Congreso de la Unión. (2010). *Ley Federal de Protección de Datos Personales en Posesión de los Particulares*. Diario Oficial de la Federación.
<https://www.diputados.gob.mx/LeyesBiblio/pdf/LFPDPPP.pdf>
- Cámara de Diputados del H. Congreso de la Unión. (2024). *Código Penal Federal* (Título Noveno: Delitos contra la indemnidad y seguridad informáticas). Diario Oficial de la Federación.
<https://www.diputados.gob.mx/LeyesBiblio/pdf/CPF.pdf>
- Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer Security Incident Handling Guide* (NIST Special Publication 800-61, Revision 2). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-61r2>
- International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC standard No. 27001:2022). <https://www.iso.org/standard/27001>
- Payment Card Industry Security Standards Council. (2022). *Payment Card Industry (PCI) Data Security Standard: Requirements and Testing Procedures Version 4.0*. PCI SSC. <https://www.pcisecuritystandards.org/>

- Check Point Research. (2025). *2025 Cyber Security Report: Global Threat Trends and Industry Analysis*. Check Point Software Technologies Ltd.
- National Institute of Standards and Technology (NIST). (2012). *Computer Security Incident Handling Guide* (NIST Special Publication 800-61 Revision 2). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-61r2>.
- Sophos. (2025). *The State of Ransomware in Education 2025*. Sophos Sector Reports.
- Amazon Web Services (AWS). (2024). *AWS Security Incident Response Guide*. AWS Whitepapers. <https://docs.aws.amazon.com/whitepapers/latest/aws-security-incident-response-guide/aws-security-incident-response-guide.html>.
- Gartner. (2023). *Market Guide for Security Orchestration, Automation and Response (SOAR)*. Gartner Research.
- IEEE Communications Society. (2021). *Distributed Denial of Service Attacks and Defense Mechanisms in Cloud Computing*. IEEE Open Journal of the Communications Society, 2, 854-877.
- ISO/IEC. (2020). *Information technology — Security techniques — Information security management systems — Overview and vocabulary* (ISO/IEC Standard No. 27000:2020). International Organization for Standardization.
- Johnson, M., & Smith, L. (2023). *Cloud-Based LMS Resilience: Mitigating Operational Downtime in Higher Education*. International Journal of Educational Technology, 15(2), 112–128.
- Ramírez, A., & Torres, E. (2024). *Modelado de Amenazas y Respuesta a Incidentes bajo la Metodología NIST en Instituciones Educativas de América Latina* [Tesis de Maestría, Universidad Tecnológica Regional]. Repositorio Institucional.
- SANS Institute. (2022). *Incident Handler's Handbook*. SANS Reading Room Whitepapers.